
Case study about the security breach at Target

ISLINGTON COLLEGE

AFFILIATED TO LONDON MET. UNIVERSITY

ARJAN U. TIMALSINA
NP01NT4A250057

Contents

0.1	Introduction	2
0.2	Unfolding	3
	0.2.1 Security	3
	0.2.2 Blunders	3
	0.2.3 Breach	3
0.3	Consequences	5
0.4	Methodologies	6
0.5	Flowchart	7

0.1 Introduction

During the last two decades in the field of cybersecurity, many incidents have taken place which has helped to bring the realm of cyber and information security to the place it is now .

Various data breaches and security threats have resulted in numerous new methods to prevent and stop such attacks. With the rapid development and reach of the internet growing ever so quickly it led to a collection of massive data including sensitive data. This also led criminals to find new tactics to do cyber crimes.

With events such as the 2013 data breach of MySpace where 360 million users had their login credentials stolen, in the same year the personal information of 3 billion Yahoo users was compromised. Still these events were not revealed by these cooperations for years. Adobe and LinkedIn were also breached, but the breach at Target would show that any field was vulnerable to data breaches.

Target was third-largest retailer in United States and operated numerous stores within Canada and U.S upto 2000 stores. It also ranked within the top 50 companies within the Fortune 500 index with millions of customers on a daily basis and a multinational chain.

The attack occurred during holiday season via the POS i.e point of sale machine where the information of 70 million customer and the credit card of 40 million users were also compromised.

0.2 Unfolding

0.2.1 Security

Every cyber crime starts with a vulnerability. Target did comply with the Payment Card Industry (PCI) Security Standards, they had firewalls, Virtual local area networks (VLAN) along with FireEye which provided multiple level of security from malware detection to network intrusion detection system (NIDS)

0.2.2 Blunders

Even though they had such level of protection they failed to detect as well as prevent some:

- They were unable to prevent the installation of malware into their POS units.
- They didn't properly look into the warnings generated by NIDS and FireEye as well as other tools
- They didn't follow proper protocol to segment their systems into different network on the basis of sensitivity of data.
- They didn't have proper access control leading to privilege escalation

0.2.3 Breach

Phase: 1 Infection

Using phishing emails the attackers were able to infect Fazio's system. What is believed to be Citadel¹

After the access into the target's network through fazio mechanical the attackers were able to access Target's Ariba external billing system or the business section of Target. These privileges were given to fazio so that they could upload their invoices. This was a huge vulnerability as the portal was not set to block executable files. Taking advantage of the access and the inability of fazio to interact with target's system the attackers were able to upload a "Web Shell"²

¹A popular malware for stealing login info

²A malicious script used to gain control on web servers

Phase: 2 PoS Infection

They named this "Webs shell to look like a authentic file, now they had remote control over the Target's servers. They then located target's secure server due to the poor segmentation done within their network. They then experimentated installing various malware on the PoS devices. They used a PoS malware called BlackPOS which is also referred to as Kaptoxa.

Phase 3: Privilege and extraction

After the access and the successful hijacking of the PoS systems the attackers were just a few steps away from entering and extracting the data but they were in need of privilege i.e Domain Admin privileges. They were able to easily enter into the system as it had single sign on, a common design that allows administrators to login only once into their system and be logged in later on. Using Pass-the-hash method they were able to easily infiltrate the system as they only needed the hashes and not the cleartext passwords to login. Thus by only using hashes they were able to gain admin privileges into the system

After successfully gaining access they used those privileges to create their own separate Domain Access account Allowing them free access along with no suspicion. They again as before layed low naming their Domain Access account after a legitimate IT application. They then took over three FTP servers³

During peak time they would harvest the info stored in the PoS systems Later sent to these FTP servers which would be passed onto other compromised machines and then to drop sites in Miami and Brazil. These data were later sold estimated to be around 11GB of data. They were later found on sale in black market forums.

³File Transfer Protocol

0.3 Consequences

After the attack was revealed a few weeks, Target faced numerous lawsuits from various parties. They later announced that this incident had caused them \$162 million in expenses related to the breach. They paid \$18.5 million to settle a multi-state lawsuit, \$10 million for federal class-action lawsuits and so on . This also led to the resignation of the CEO Gregg Steinhafel and CIO Beth Jacob. This whole incident is believed to have caused Target \$1 billion in expenses.

0.4 Methodologies

Here we will go indepth about the malware and exploits used and their functionalities:

BlackPOS or Kaptoxa Initially seen on underground forums since Feb 2013, it is believed to be the major malware used in the data breaches at Target(2013),P.F Chang's(2013) & Home Depot(2014). This mainly target Windows based POS machines. It would register itself as a Windows Service named "POSWDS" it would scan a list of processes and communicate with a compromised server (internal server repo) to upload the retrieved card informtaion.This fuction could only be enabled during the busy hours. They are analyzed in chunks and stored in a system ".dll" file which would periodically upload to the intrenal repo via NetBIOS⁴ and SMB⁵protocols

Citadel Citadel is a powerful banking trojan. Banking troans intercept communication with your bank to access your PINs⁶ and TANs⁷. Causing significant financial damage. It can be installed on a victim's computer with a drive-by-download attack most often using other exploit kits.Citadel then installs Reveton, a very bad ransomeware virus.These viruses then steal crucial finanxial data and login credentials while simultaneously making the computer a part of a botnet for other attacks.

Pass-the-hash Pash the hash is a cybersecurity attack where the attacker steals a "hashed" i.e kind of a session or login identifier and uses this stolen hash to create a new user session under the same privilege as the actual user. It bypasses the need for passwords only requiring the associated plaintext hash.

⁴A old APi session layer that allows communication within a LAN

⁵Server Messege Block a protocol for shared access to files on a network

⁶Persnal Identification Number

⁷Transaction Authentication Number

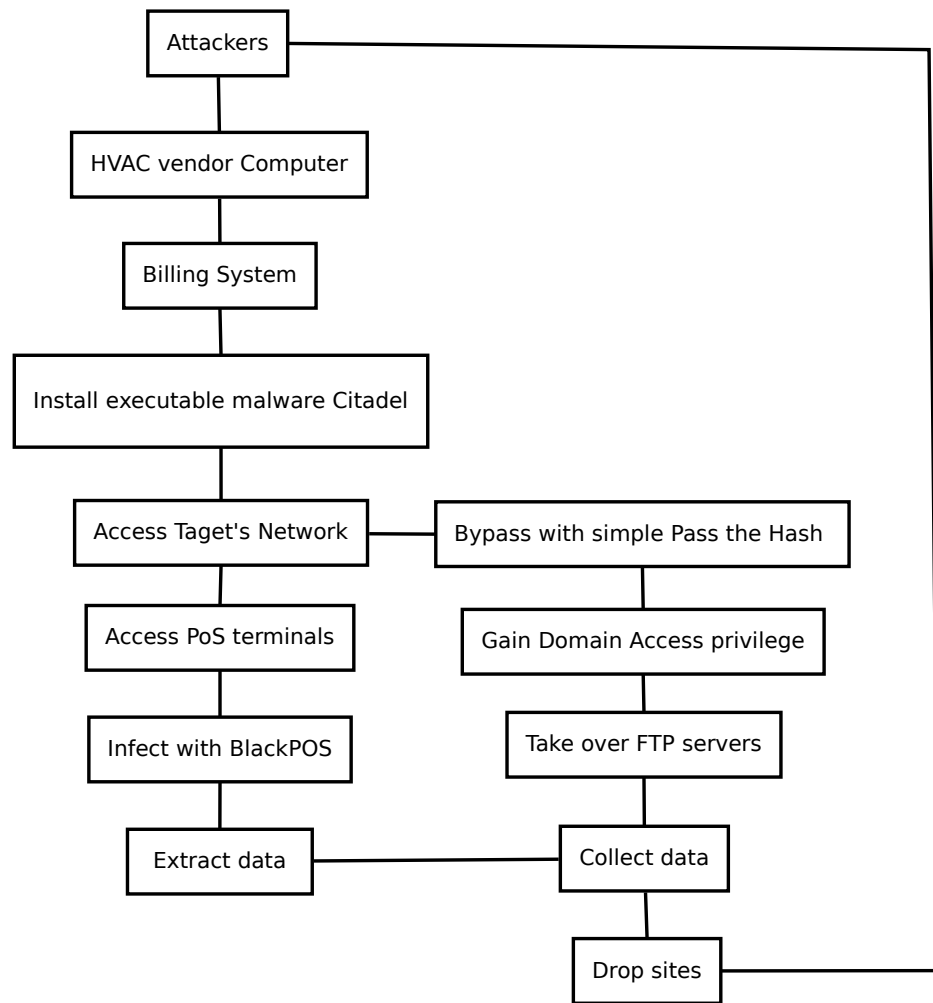


Figure 1: *A flowchart of the attack*